

SECURITY INCIDENT ANALYSIS

Case Studies: Phishing Attack & Web Server Traffic Spike

Name:- SHIAK REEHAN

Reg no: -192565071

Course code: -CSA6001

SCENARIO 1: PHISHING ATTACK

Classification	Incident Type	Priority Level
Security Incident	Phishing → Account Compromise	HIGH / P2

1. Executive Summary

An employee received a phishing email impersonating the organization's IT department, requesting urgent password verification via an embedded hyperlink. The employee clicked the link and submitted credentials. Within minutes, multiple login attempts originating from an unfamiliar foreign IP address were observed against the employee's account. Analysis of the email headers confirms the sender's domain does not match the organization's legitimate domain. This sequence of events indicates that the phishing attempt succeeded in harvesting valid credentials and that the credentials are actively being used by an unauthorized third party, constituting a confirmed security incident requiring immediate response.

2. Security Event vs. Security Incident Determination

A security event is any observable occurrence in a system or network (e.g., a phishing email being delivered or a login attempt). A security incident is an event that has been confirmed to violate security policy, resulted in unauthorized access, or caused (or is likely to cause) harm to confidentiality, integrity, or availability of information assets.

Determination: This is a SECURITY INCIDENT, not merely a security event

Justification:

- Receipt of the phishing email alone would only constitute a security event.
- The employee's interaction with the malicious link and submission of credentials represents a confirmed compromise of authentication data.
- Subsequent login attempts from an unfamiliar foreign IP address indicate the stolen credentials are actively being used by a threat actor — evidence of unauthorized access attempts, and potentially a successful account takeover.
- The mismatch between the sender's domain and the organization's official domain confirms malicious intent and spoofing, ruling out a false positive or legitimate IT communication.

Because there is confirmed unauthorized activity (not just suspicious signals), this event set has escalated into an active security incident.

3. Incident Classification

Primary Category: Phishing / Social Engineering Attack

Secondary Category: Credential Compromise → Unauthorized Access / Account Takeover Attempt

Attack Vector: Spoofed email with malicious hyperlink (credential harvesting page)

MITRE ATT&CK Mapping: T1566.002 (Phishing: Spearphishing Link), T1078 (Valid Accounts)

This incident falls into the category of Identity/Credential-based Attacks. It began as a social engineering (phishing) attack and progressed into a potential unauthorized access incident once the credentials were used from an external, unrecognized location.

4. Priority / Severity Level Assignment

Assigned Priority: HIGH (P2) — escalate to Critical (P1) if account has privileged/admin access or if lateral movement is confirmed

Justification for HIGH priority:

- Confirmed credential compromise (not just a suspected/undelivered phishing attempt).
- Active exploitation evidence: multiple login attempts from a foreign, unrecognized IP shortly after credential submission.
- Potential for account takeover, data exfiltration, lateral movement, or further phishing (internal spearphishing) using the compromised account.
- Regulatory/compliance exposure if the account has access to sensitive, financial, or customer data.

Priority would be raised to CRITICAL (P1) if the compromised account has administrative privileges, access to sensitive systems, or if evidence of successful login (not just attempts) or data access is confirmed.

5. Supporting Evidence

Evidence	Significance
Sender domain mismatch	Email headers show the sending domain does not match the organization's official domain — confirms spoofing/impersonation.
Urgency/pressure language	Request for “immediate password verification” is a classic social engineering pressure tactic used to bypass user judgment.
User interaction timeline	Employee clicked the link and logged in within minutes of receipt, confirming credential submission on a malicious page.
Anomalous login attempts	Multiple login attempts from an unfamiliar foreign IP shortly after credential entry indicate the harvested credentials are being actively used/tested by a threat actor.
Geolocation anomaly	Foreign IP address is inconsistent with the employee's normal login geography, supporting unauthorized access rather than legitimate use.

6. Immediate First Response Actions

6.1 Containment (0–30 minutes)

- Immediately disable/lock the affected user account to block further unauthorized login attempts.

- Force a password reset for the affected account through an out-of-band, verified channel (not the compromised device).
- Revoke active sessions and issued tokens (SSO, VPN, cloud, email) associated with the account.
- Enforce or re-verify multi-factor authentication (MFA) on the account before re-enabling access.
- Block the identified malicious sender domain and foreign source IP address at the email gateway and firewall/proxy.

6.2 Investigation (concurrent, first hour)

- Preserve the original phishing email and full headers for forensic analysis.
- Review authentication logs to determine whether any login from the foreign IP succeeded, not just attempted.
- Check for mailbox rule changes, forwarding rules, or OAuth app grants that may indicate persistence.
- Search email logs to identify whether the same phishing email was sent to other employees (mass-mail check).
- Identify what systems/data the compromised account has access to, to assess blast radius.

6.3 Eradication & Recovery

- Remove the phishing email from all mailboxes organization-wide.
- Scan the employee's device for malware, keyloggers, or persistence mechanisms if credentials may have been captured via a compromised endpoint.
- Restore account access only after password reset, MFA verification, and confirmation the device is clean.

6.4 Communication & Reporting

- Notify the incident response team lead and escalate per the organization's incident response plan.
- Alert affected employee and relevant department manager.
- Notify legal/compliance if regulated data may have been exposed (e.g., PII, financial records).
- Document the incident timeline, actions taken, and evidence in the incident tracking system for post-incident review.

6.5 Post-Incident

- Conduct a root-cause and lessons-learned review.
- Reinforce phishing awareness training for all staff, emphasizing verification of sender domains and IT's actual communication practices.
- Consider implementing/tightening email authentication controls (SPF, DKIM, DMARC) to reduce future domain-spoofing success.

7. Recommendations to Prevent Recurrence

- Deploy or tune email security gateway rules to flag/quarantine emails with domain spoofing or look-alike domains.
- Implement DMARC enforcement (p=reject) alongside SPF and DKIM.
- Enforce MFA organization-wide so a stolen password alone cannot grant access.
- Conduct periodic simulated phishing exercises to measure and improve employee resilience.
- Establish a one-click “Report Phishing” button in the email client to speed up detection and response.
- Apply geo-velocity/impossible-travel alerting rules in the SIEM to auto-flag logins from unusual locations.

SCENARIO 2: WEB SERVER TRAFFIC SPIKE

Classification	Incident Type	Priority Level
Security Incident	DDoS (Volumetric / Application-Layer)	CRITICAL / P1

1. Executive Summary

A web server experienced a sudden, massive surge of HTTP requests originating from hundreds of distinct IP addresses within a short time window. The server became slow and unresponsive, legitimate users were unable to access the website, Apache access logs showed repeated requests to the same webpage, and network monitoring confirmed abnormally high inbound bandwidth consumption. This pattern is consistent with a Distributed Denial-of-Service (DDoS) attack aimed at exhausting server and network resources. Given the confirmed impact on availability for legitimate users, this is classified as an active, high-severity security incident requiring immediate containment.

2. Security Event vs. Security Incident Determination

A traffic increase alone (e.g., a marketing campaign or viral link) would be a security event worth monitoring. This scenario crosses into a security incident because there is confirmed, measurable harm to system availability and legitimate business operations.

Determination: This is a SECURITY INCIDENT, not merely a security event

Justification:

- Traffic did not just increase — it caused a measurable, adverse impact: the server became slow and legitimate users were denied access (a confirmed availability breach of the CIA triad).
- The traffic pattern is abnormal and distributed: hundreds of different source IPs hitting the server simultaneously is not consistent with organic or legitimate usage growth.
- Repeated requests to the same webpage from many sources is a signature of an automated/coordinated attack (e.g., botnet), not real user behavior.
- Network monitoring independently corroborates the application-layer log evidence, confirming the anomaly is real and resource-exhausting, not a logging artifact.

Because availability has been actively degraded and the traffic pattern shows clear signs of coordination, this qualifies as a confirmed security incident, not just a benign or unconfirmed event.

3. Incident Classification

Primary Category: Denial-of-Service Attack — Distributed Denial-of-Service (DDoS)

Likely Sub-Type: Application-Layer (Layer 7) HTTP Flood, potentially combined with volumetric/network-layer flooding

Attack Vector: Botnet-driven mass HTTP GET/POST requests from hundreds of distributed IP addresses

MITRE ATT&CK Mapping: T1498 (Network Denial of Service), T1499 (Endpoint Denial of Service / Application Exhaustion Flood)

The evidence points to a DDoS attack rather than a simple Denial-of-Service (DoS), because traffic is originating from hundreds of different IP addresses rather than a single source — indicative of a botnet or distributed attack infrastructure. The repeated requests to one specific webpage suggest an HTTP flood (Layer 7) designed to exhaust server-side resources (CPU, memory, database/application threads) rather than purely saturating network

bandwidth, though the bandwidth consumption noted by monitoring tools suggests a volumetric component may also be present.

4. Priority / Severity Level Assignment

Assigned Priority: CRITICAL (P1)

Justification for CRITICAL priority:

- Confirmed, active loss of availability: legitimate users are currently unable to access the website — this is a direct, ongoing business impact, not a theoretical risk.
- Public-facing service disruption can cause immediate reputational, financial, and customer-trust damage.
- Scale of the attack (hundreds of source IPs, bandwidth saturation) indicates a coordinated, resourced attacker, which may escalate further or be a diversion for a secondary attack (e.g., exploitation attempt during the chaos).
- Every minute of downtime has a direct, measurable cost — this requires an immediate, all-hands response rather than standard queue handling.

5. Indicators Supporting the Conclusion

Indicator	Significance
Sudden spike in request volume	Rapid, abnormal jump in HTTP requests within minutes is inconsistent with organic traffic growth patterns.
Hundreds of distinct source IPs	Distribution across many IPs rules out a single misbehaving client and strongly suggests a botnet-driven, coordinated (distributed) attack.
Server performance degradation	Slow response times indicate server resources (CPU, memory, connections) are being exhausted by the request volume.
Legitimate users denied access	Confirms actual, measurable impact to availability — the defining criterion that elevates this from an event to an incident.
Repeated requests to same page (Apache logs)	Classic HTTP flood / Layer 7 DDoS signature; targeting one resource is typical of scripted/automated attack tools.
Excessive inbound bandwidth (network monitoring)	Independent network-layer confirmation that the anomaly is consuming real infrastructure capacity, corroborating the log evidence.

6. Containment Measures

6.1 Immediate Containment (0–30 minutes)

- Enable/activate DDoS protection or scrubbing services (e.g., cloud-based DDoS mitigation, CDN, or ISP-level scrubbing) if available.
- Apply rate limiting on the web server/load balancer to cap requests per IP address within a given time window.
- Block or throttle the identified malicious/anomalous source IP ranges at the firewall or upstream router.
- Enable a Web Application Firewall (WAF) with rules to filter known bad bot signatures and enforce challenge mechanisms (e.g., CAPTCHA, JavaScript challenge) for suspicious requests.

- If capacity allows, temporarily scale up server/CPU resources or enable auto-scaling to absorb load while mitigation is applied.

6.2 Short-Term Mitigation (concurrent, first hour)

- Redirect traffic through a Content Delivery Network (CDN) to absorb and cache requests closer to the edge, reducing origin server load.
- Enable SYN cookies / connection limits at the network layer if network-layer flooding is also confirmed.
- Geo-block or restrict traffic from regions with no legitimate business need, if the attack sources are concentrated geographically.
- Coordinate with the ISP/hosting provider to apply upstream traffic filtering for very large volumetric spikes.

6.3 Investigation & Evidence Preservation

- Preserve Apache access logs, firewall logs, and network monitoring data covering the attack window for forensic analysis.
- Analyze request patterns (user-agent strings, request headers, timing) to fingerprint the botnet/tooling used.
- Determine whether the targeted webpage has any special significance (e.g., login page, checkout page, API endpoint) that may indicate a targeted rather than opportunistic attack.

6.4 Communication & Recovery

- Notify the incident response team, hosting/cloud provider, and relevant stakeholders (e.g., management, customer support) of the ongoing incident and expected impact.
- Post a status update on a status page or alternate channel to inform legitimate users of the disruption.
- Once traffic normalizes, gradually remove emergency rate limits/geo-blocks while monitoring for renewed attack activity.

6.5 Post-Incident

- Conduct a post-incident review to assess mitigation effectiveness and time-to-containment.
- Evaluate and, if needed, procure a dedicated DDoS mitigation/CDN service for ongoing protection.
- Update incident response runbooks with lessons learned and refine automated detection thresholds (e.g., SIEM alerts for request-rate anomalies) for faster future detection.

7. Recommendations to Prevent Recurrence

- Deploy a permanent WAF and DDoS mitigation/CDN solution in front of all public-facing web assets.
- Implement auto-scaling and load-balancing architecture to absorb legitimate traffic surges and reduce single-point failure risk.
- Set up real-time SIEM/network monitoring alerts for abnormal request-rate or bandwidth thresholds to enable earlier detection.
- Maintain an up-to-date incident response and business continuity plan specifically covering DDoS scenarios, including provider escalation contacts.
- Regularly test defenses through simulated load/stress testing to validate mitigation capacity.

End of Report